

Part B 两阶段五人分工表

目标

以 Part B 高分/满分为目标，团队最终只提交一个最高影响、合法 scope 内、证据充分、最好具备 zero-day candidate 支撑的 finding。

核心原则：

- 第一阶段全员并行找漏洞，最大化候选 finding 覆盖面
 - 第二阶段统一汇总、评分、筛选，再围绕最强 finding 集中深挖
 - 所有测试必须严格遵守 bug bounty scope、禁止 DoS/破坏性测试
 - 最终 presentation 只围绕一个最强 finding 展开
-

总体执行路径

阶段 1：全员外拓找候选漏洞

时间建议：1-2 天。

目标：每个人独立负责一组合法 bug bounty 目标，快速产出候选 finding，而不是一开始就押注单一目标。

每个人至少提交：

- `targets-shortlist.md`：看过哪些合法项目，为什么选择/放弃
- `scope.md`：目标是否 in scope，允许和禁止什么
- `test-plan.md`：计划测试哪些功能、权限边界、账号角色
- `candidate-findings.md`：目前发现或怀疑的问题
- 证据草稿：截图、请求/响应、日志、复现步骤、时间戳

阶段 2：汇总评分并集中深挖

时间建议：第一阶段结束后立即开 30-45 分钟同步会。

目标：把所有候选 finding 放在同一套标准下评分，选出 1-2 个最有希望的 finding 继续验证，最后收敛到一个最终提交 finding。

统一筛选标准：

- 是否来自合法 bug bounty program 或 spec 明确允许的 company-run program
- 是否明确 in scope, 测试行为是否安全、低风险、可解释
- 是否可复现, 是否能被另一个成员独立复核
- 是否影响真实资产、真实数据、权限边界或平台完整性
- 是否可能达到 S3/S4, 或至少具备清晰 CVSS/platform severity mapping
- 是否可能是 zero-day candidate, 是否有公开披露排查证据
- 是否能在 5 分钟 presentation 和 Q&A 中讲清楚、defend 住

满分导向验收标准

最终保留的 finding 必须尽量满足:

- Scope handling: 目标 URL、program 来源、in-scope asset、legal boundary、测试账号/测试边界都有证据
- Reproducibility: 复现步骤足够清晰, 至少一名非发现者成员能独立复核
- Severity: 优先 S4/Critical; 如果只能到 S3/High, 必须有非常强的影响证据
- Impact evidence: 能证明 exploit path、affected asset/data、real-world consequence, 不能只停留在猜测
- Novelty: zero-day candidate 必须有公开披露排查记录; 若是 non-zero-day, 必须证明公开已知且当前测试版本仍可利用
- Presentation: 5 分钟内清楚覆盖 target、root cause、reproduction、impact、severity、novelty、mitigation
- Q&A: 能用证据回答 scope、impact、severity、novelty、safe testing、每人贡献

阶段 1 分工: 全员并行找漏洞

成员 1: GitHub / npm / Developer Platform 方向

优先目标:

- GitHub Bug Bounty
- npm 相关资产
- 其他开发者平台、CI/CD、package registry 类项目

重点测试方向:

- Repository 权限边界
- Organization invite / role 权限

- Private repository 可见性
- GitHub App / OAuth 权限
- Actions / workflow 权限边界
- Package ownership / private package 访问控制

阶段 1 交付物：

- 合法 scope 证据
- 2-3 个可测试功能点
- 至少 1 个候选 finding 或明确说明为什么暂时放弃

成员 2：AI Platform / Model Safety / Agent 方向

优先目标：

- OpenAI Bug Bounty
- Anthropic Model Safety Bug Bounty
- 其他明确在合法平台内的 AI/agent/integration 类项目

重点测试方向：

- Agentic prompt injection
- Data exfiltration
- Cross-session / cross-user data exposure
- Platform integrity bypass
- Account boundary / feature access boundary
- MCP / third-party tool interaction 风险

注意事项：

- 避免普通 jailbreak、无实质影响的 policy bypass
- 必须证明真实安全影响，而不是单纯模型回答不理想

阶段 1 交付物：

- Security bounty 与 safety bounty scope 区分
 - 可测试功能边界
 - 候选 finding 或不可行原因
-

成员 3: HackerOne / Bugcrowd 中小型 Web 项目方向

优先目标:

- HackerOne opportunities
- Bugcrowd programs
- 中小型 SaaS、协作工具、仪表盘、API 平台

重点测试方向:

- IDOR / Broken Access Control
- OAuth / SSO 权限边界
- Webhook / integration 权限
- Invite / team / role 权限问题
- API object ownership 验证

阶段 1 交付物:

- 2-3 个目标 shortlist
 - 每个目标的 scope 与 severity 规则摘要
 - 至少 1 个候选 finding 或高潜力测试面
-

成员 4: Intigriti / YesWeHack / Immunefi 方向

优先目标:

- Intigriti programs
- YesWeHack programs
- Immunefi programs
- 其他平台内明确合法的项目

重点测试方向:

- Tenant isolation
- File upload / preview / rendering
- API authorization
- Business logic / workflow bypass
- High-impact web3 issue only if team能安全理解和复现

阶段 1 交付物:

- 目标筛选记录
 - scope / out-of-scope 摘要
 - 候选 finding 证据草稿
-

成员 5：Scope + Evidence 模板负责人，同时参与找漏洞

成员 5 第一阶段不是只等最后做 presentation，也要负责一个目标方向，同时维护统一证据格式。

优先目标：

- 从 HackerOne、Bugcrowd、Intigriti、YesWeHack 中补位选择目标
- 优先找 scope 清晰、账号容易创建、功能边界明显的项目

额外职责：

- 设计统一证据模板
- 规范截图、日志、录屏命名方式
- 维护 activity-log 草稿
- 维护 ai-log 草稿

阶段 1 交付物：

- evidence-template.md
 - 自己负责目标的 scope/test-plan/candidate-findings
 - 团队证据目录规范
-

阶段 2 分工：汇总、评分、深挖、展示

阶段 2 开始后，不再按“谁发现谁独自负责”推进，而是全组围绕最强候选 finding 分工。

成员 1：Target + Scope Proof

负责证明最终 finding 合法、in scope、测试方式安全。

交付物：

- 目标来源与 bug bounty program 链接
- in-scope asset 证据

- out-of-scope 风险说明
- 测试账号、测试边界、无破坏性说明

成员 2: Root Cause + Technical Explanation

负责解释漏洞根因和技术机制。

交付物：

- 漏洞发生在哪里
- 为什么权限/信任边界失效
- 关键请求、参数、配置或流程说明
- 简洁技术图或流程图

成员 3: Reproduction + Independent Verification

负责把 finding 变成稳定、可复核的复现流程。

交付物：

- 最短复现步骤
- 请求/响应或截图证据
- 第二账号/第二成员复核记录
- 失败条件与限制说明

成员 4: Impact + Severity + Novelty

负责最终评分、防守和公开披露排查。

交付物：

- platform severity 或 CVSS v3.1 fallback mapping
- S1-S4 normalized severity 说明
- 真实影响：受害者、数据/资产、攻击后果
- Type 1 / Type 2 / zero-day duplicate 分类建议
- 公开披露排查记录

公开披露排查来源：

- Google Search
- CVE / NVD

- GitHub Security Advisories
- GitHub Issues / Discussions
- HackerOne disclosed reports
- Bugcrowd / Intigriti disclosed reports
- Vendor changelog / release notes
- Official documentation / known limitations

成员 5: Evidence + Presentation + Q&A

负责把最终 finding 组织成 5 分钟 presentation 和 Q&A 材料。

交付物:

- presentation-outline.md
- presentation-script.md
- mock-qna.md
- ai-log/
- activity-log.pdf
- 最终证据包目录整理

阶段 2 同步会议议程

第一阶段结束后，全组开一次同步会，只做 finding selection。

建议议程:

1. 每人 3 分钟汇报候选 finding
2. 全组用统一评分表打分
3. 选出 1-2 个最高潜力 finding
4. 指定一个成员做独立复核
5. 24 小时内决定最终只保留一个 finding

候选 finding 评分表:

维度	问题	分值
Scope	是否合法 in scope	0-2
Reproducibility	是否稳定可复现	0-2
Impact	是否影响真实资产/权限边界	0-3
Severity	是否可能达到 S3/S4	0-3
Novelty	是否可能是 zero-day candidate	0-2
Presentability	是否能 5 分钟讲清楚	0-2

最终 Part B 10 分影响行自检：

Rubric 项	满分要求	负责人
Severity score	S4/Critical 或 CVSS ≥ 9.0 可证；平台 severity 优先	成员 4
Impact-evidence score	exploit path、affected asset/data、real-world consequence 都有证据	成员 2、3、4
Novelty score	zero-day candidate 有公开披露排查；或 non-zero-day 证明仍可利用	成员 4

最终 Presentation 分工建议

最终 presentation 只围绕一个最强 finding 展开。

成员	内容	时间
成员 1	Target + scope proof	40-50 秒
成员 2	Root cause	40-50 秒
成员 3	Reproduction	50-60 秒
成员 4	Impact + severity + novelty	70-80 秒
成员 5	Mitigation + ethics + wrap-up	40-50 秒

要求：

- 每位成员至少发言 40 秒

- 总时长不超过 5 分钟
- 避免讲多个 finding
- 所有结论必须有证据支撑
- Q&A 时优先回答 scope、impact、severity、novelty、safe testing

最终提交物检查清单

Assignment 2 最终 required files:

- `report.pdf` : Part A only, USENIX 模板, 最多 2 页
- `parta-presentation.mp4` : Part A 录制视频, 最多 5 分钟
- `ai-log/` : AI 使用记录、外部工具/文档引用、rubric-driven mock Q&A 改进记录
- `presentation.mp4` : Part B 录制视频, 最多 5 分钟, 只讲最高影响 in-the-wild finding
- `activity-log.pdf` : 每位成员贡献记录

Part B 不需要单独 written report, 但 presentation 和 Q&A 必须能展示/ defend:

- target: 目标是什么、来自哪个合法 bug bounty program
- scope proof: 目标 URL、in-scope asset、legal boundary、测试限制
- vulnerability: 哪里出错, root cause 是什么
- reproduction: 可复现步骤、账号角色、请求/响应、截图或日志
- impact: 攻击者能做到什么, 谁受影响, 哪些资产/数据受影响
- severity: 平台 severity 或 CVSS v3.1 fallback, 并映射到 S1-S4
- finding type: Type 1、Type 2 zero-day candidate, 或 zero-day duplicate
- novelty: 公开披露排查证据、搜索关键词、查过的来源、结论
- mitigation: 具体修复建议, 以及为什么能降低风险
- ethics: 测试安全、低风险、无 DoS、无越界访问真实用户数据

提交风险提醒:

- 缺少任一 required file 会从 Assignment 2 总分扣 5 分
- Part B presentation 超过 5 分钟, 每多 10 秒扣 1 分
- 每位成员 Part B 发言至少 40 秒, 否则该成员个人分会按比例下调
- 最终只提交并 defend 一个 in-the-wild finding, 避免 presentation 分散到多个漏洞